CA2 – Security Testing and Report Securing the Network – Jones Café & Bakery

Silmara Souto

Phase 1: Security Recommendations Report

1.1 Introduction

This report was prepared as part of a security consultation for Jones Café & Bakery. Building on the work done in CA1, this phase goes deeper into the security problems found in the network and gives more detailed recommendations. The report covers three main areas: the on-premise network, the web server before it goes live, and the AWS cloud platform where the website is hosted.

1.2 Current Network Problems

Looking at the Jones Café network, there are several serious problems that need to be fixed before the website goes live. These problems fall into four categories that are common in many organisations (Weiss, 2026): technology weaknesses, configuration weaknesses, policy weaknesses, and human error.

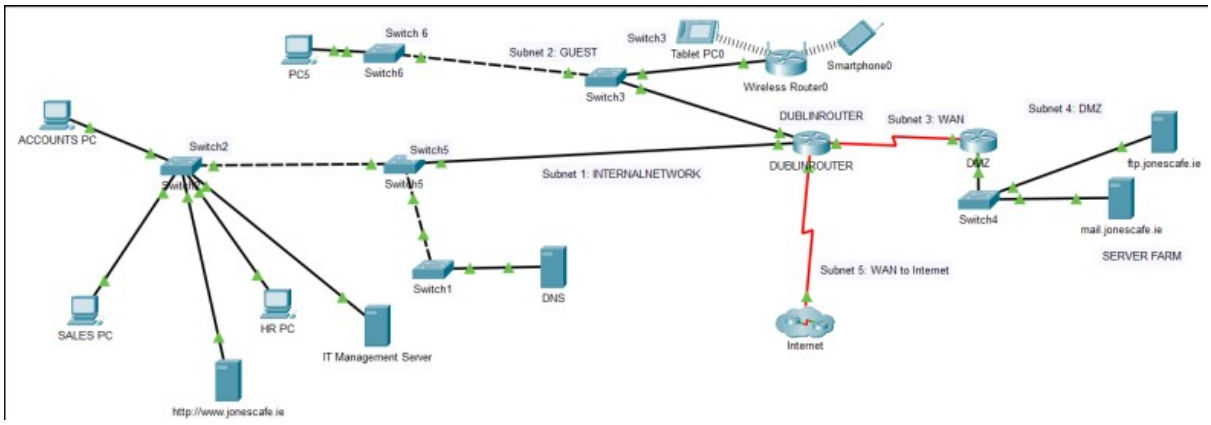


Figure 1 Original Jones Café network infrastructure (source: assignment brief)

Outdated Systems

The network is running Windows Server 2016 and Ubuntu Server 16.04. Both of these systems are no longer receiving security updates. This means any new vulnerability discovered in these systems will never be fixed by the manufacturer. A real example of this danger is CVE-2017-0144, the vulnerability used in the WannaCry ransomware attack. That attack hit unpatched Windows systems around the world and caused over £92 million in damage to the UK's National Health Service alone (NCSC, 2018). Jones Café is at risk of the same type of attack if these systems are not updated.

Web Server in the Wrong Place

The website (www.jonescafe.ie) is currently inside the INTERNALNETWORK subnet. This is a major problem. If an attacker finds a vulnerability in the website and breaks in, they will immediately have access to internal systems like the Sales PC, HR PC, and Accounts PC. According to Cisco (2021), web servers must be separated from the internal network because they are the most common target for attacks.

Shared Accounts and No Security Policies

Staff members are sharing accounts and passwords. This makes it impossible to know who did what if something goes wrong. It also means that if one person's credentials are stolen, an attacker has access to everything that person can access. There are also no documented security policies and no patch management process the IT support shop closed nine months ago and nothing has been updated since.

1.3 On-Premise Network Recommendations

Patch Management

The first rule of computer security is to keep all systems patched (Weiss, 2026). Jones Café should upgrade Windows Server 2016 to Windows Server 2022 and Ubuntu 16.04 to Ubuntu Server 24.04 LTS. A regular patch cycle should be introduced checking for critical updates weekly and testing patches on a non-production system before applying them to live servers (NIST, 2022).

Network Segmentation with VLANs

The network should be divided into VLANs to keep different types of traffic separate:

- VLAN 10 – Internal Network: staff computers, DNS, IT Management Server
- VLAN 20 – Guest Network: customer Wi-Fi, tablets, smartphones
- VLAN 30 – DMZ: web server, mail server, FTP server

For example, if a customer on the guest Wi-Fi gets a virus on their phone, VLANs will stop it from spreading to the internal staff computers. Without this, an attacker can use a MAC flooding attack to fill the switch's memory table and see all traffic on the network (Cisco, 2021).

Firewall Rules

A firewall should control traffic between every zone. The key rules are:

- Allow HTTP (port 80) and HTTPS (port 443) from the internet to the web server only
- Block all traffic from the guest network to internal systems
- Block traffic from the DMZ going into the internal network
- Deny everything else by default if it is not explicitly allowed, it is blocked

Every open port is a possible way in for an attacker. The rule is: if you do not need it, close it (Weiss, 2026).

Individual Accounts and MFA

Every employee must have their own individual account in Active Directory. Shared accounts must be removed. Role-based access control (RBAC) should be applied so each person can only access what they need for their job. MFA should be enabled for all admin accounts and remote access. The 2024 Verizon Data Breach Investigations Report found that 68% of breaches involved stolen or weak credentials (Verizon, 2024).

Switch Security

Layer 2 the switch level is often the weakest part of a network (Cisco, 2021). The following steps should be applied:

- Port security: limit each port to one MAC address and shut it down if a different device connects
- Disable all unused ports and assign them to a separate VLAN
- Enable DHCP snooping to block rogue DHCP servers
- Use SSH instead of Telnet for remote management of all network devices

Example: if a staff member plugs their personal router into a switch port, port security will automatically shut that port down preventing an unauthorised wireless access point inside the café.

Staff Training

Because most employees have little IT knowledge, security awareness training is essential. Training should cover how to spot phishing emails, how to create strong passwords, and why sharing accounts is dangerous. Human error is one of the most common causes of security breaches (Weiss, 2026). In Ireland, phishing was the most common initial attack method reported in 2023 (NCSC Ireland, 2023).

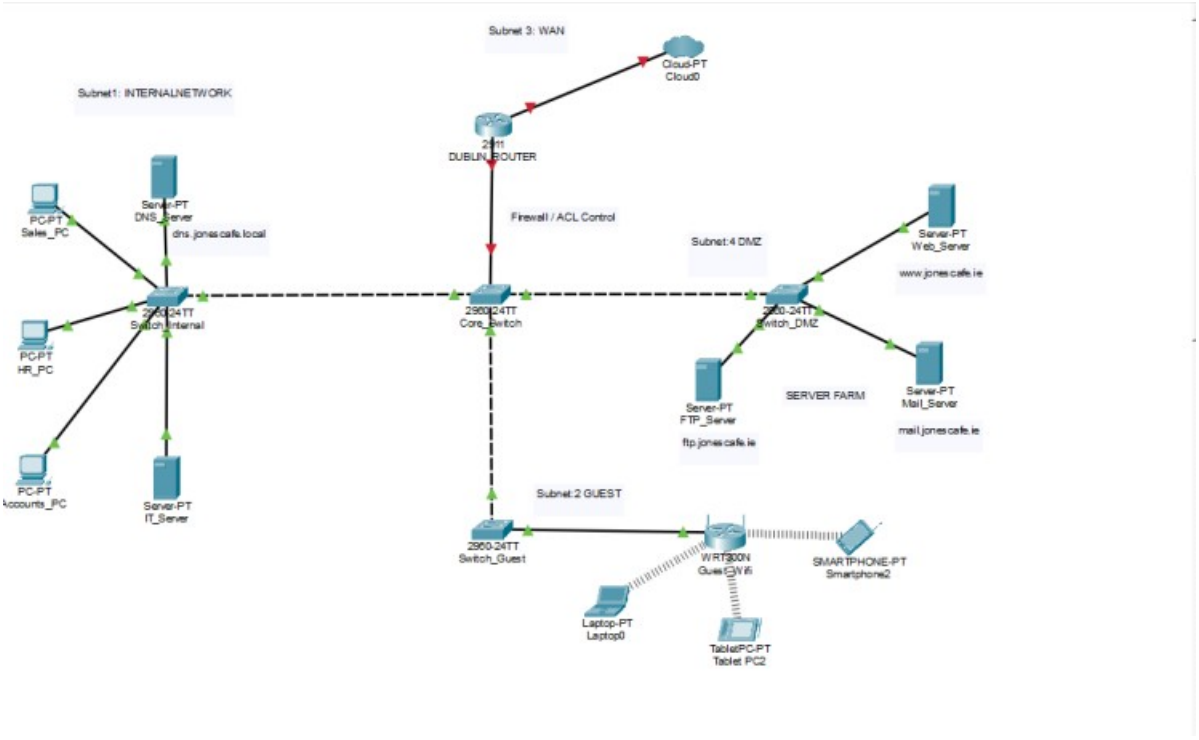


Figure 2 Figure 2: Redesigned network architecture Jones Café (Packet Tracer)

1.4 Web Server Hardening Before Going Live

Before the web server is moved from the internal network into the DMZ and opened to internet traffic, the following steps must be completed:

- **Upgrade the OS:** Ubuntu 16.04 is end of life. It must be upgraded to Ubuntu Server 24.04 LTS before going public.
- **Apply all patches:** Run sudo apt update && sudo apt upgrade to install all pending security fixes.
- **Disable unused services:** Turn off Telnet, FTP, and anything else not needed. Each running service is an extra risk (Weiss, 2026).
- **Install HTTPS/SSL:** Use a free certificate from Let's Encrypt. Without HTTPS, customer data is sent in plain text and can be intercepted.
- **Enable a host firewall (UFW):** Allow only ports 80 and 443. Block everything else at the server level.
- **Disable root SSH login:** Set PermitRootLogin no in the SSH config file and use a dedicated admin user instead.
- **Enable logging:** Record all access and failed login attempts. Logs must be checked regularly.
- **Do not store payment data on the server:** Use a third-party payment provider like Stripe or PayPal to handle all transactions.
- **Scan before launch:** Run a vulnerability scan with Nessus or Nikto (covered in Phase 7) before exposing the server to the internet.

1.5 AWS Cloud Security Recommendations

The Jones Café website is hosted on the AWS Cloud Platform. After logging into the AWS Management Console and exploring the available security services, the following recommendations were identified.

IAM – Identity and Access Management

IAM controls who can access AWS resources and what they can do. Jones Café should create individual IAM accounts for each administrator no shared root account. MFA should be enabled on the root account. Each user should only have access to what they need (AWS, 2024).



Figure 3: AWS IAM – Identity and Access Management console

Security Groups – Cloud Firewall

Security Groups act as a firewall for AWS EC2 instances. A custom Security Group should be created that allows only ports 80 and 443 from the internet, and port 22 (SSH) only from the administrator's IP address. All other traffic should be blocked (AWS, 2024).

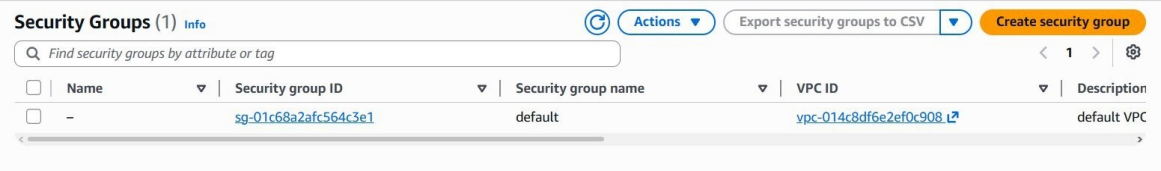


Figure 4: AWS Security Groups – default group visible in the console

WAF & Shield – Web Firewall and DDoS Protection

AWS WAF & Shield protects the website against malicious traffic and DDoS attacks. AWS Shield Standard is included for free. AWS WAF should be enabled with managed rules to block SQL injection, cross-site scripting, and known malicious IPs. A DDoS attack could take the website offline completely, meaning lost sales for Jones Café (AWS, 2024).



Figure 5: AWS WAF & Shield – protects against DDoS and malicious web traffic

Amazon GuardDuty – Threat Detection

GuardDuty monitors the AWS account automatically and alerts when it detects suspicious activity such as an unusual login from a different country or unexpected API calls. This is very useful for a small business like Jones Café that does not have a dedicated security team (AWS, 2024).



Figure 6: Amazon GuardDuty – intelligent threat detection

AWS CloudTrail – Activity Logging

CloudTrail records every action taken in the AWS console who did what, when, and from where. For example, if a Security Group is changed to allow all traffic, CloudTrail will record who made that change. This is essential for investigating incidents and should be enabled in all regions (AWS, 2024).



Figure 7: AWS CloudTrail – tracks all user activity and API usage

AWS Config – Configuration Monitoring

AWS Config tracks changes to AWS resources and can detect misconfigurations automatically. For example, if a Security Group is changed to allow all inbound traffic

(0.0.0.0/0), AWS Config will flag this as a violation helping prevent accidental security holes (AWS, 2024).



Figure 8: AWS Config – tracks resource inventory and configuration changes

Amazon Inspector – Vulnerability Scanning

Amazon Inspector automatically scans EC2 instances for known vulnerabilities from the CVE database. It reports issues like unpatched software or services exposed to the internet that should not be. For Jones Café, this means the web server will be scanned continuously without manual checks (AWS, 2024).

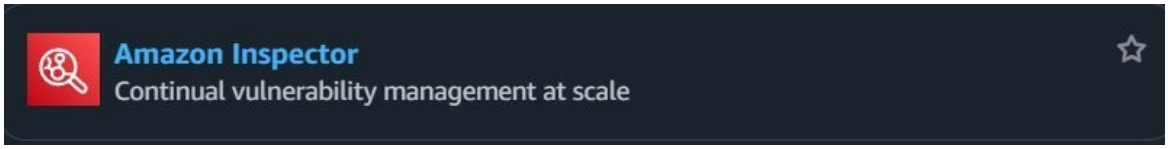


Figure 9: Amazon Inspector – continual vulnerability management

1.6 Conclusion

Jones Café has several serious security problems that need to be fixed before the website goes live. The most urgent steps are upgrading outdated systems, moving the web server into the DMZ, removing shared accounts, and applying proper firewall rules. On the AWS side, services like IAM, WAF, GuardDuty, and CloudTrail provide strong cloud security without needing a large team to manage them. Together, these recommendations will significantly improve the security of the organisation and help protect customer data as required by GDPR and PCI-DSS.

Phase 2: OWASP Website Vulnerability Report

2.1 The Risk: A03 – Injection (SQL Injection)

The OWASP Top 10 is a list of the most critical web application security risks, published by the Open Web Application Security Project (OWASP, 2021). This section focuses on A03: Injection specifically SQL Injection. This risk was ranked number one in the 2017 edition and remains one of the most dangerous vulnerabilities today because it is easy to exploit and can cause serious damage, including full database exposure.

2.2 How Jones Café Could Be Vulnerable

The Jones Café website will have a login page, a search function, and an order form all of which interact with a database storing customer names, addresses, and payment details. SQL Injection happens when an attacker inserts their own SQL commands into a form field because the application does not properly check user input (OWASP, 2021).

The website was set up by a local computer shop with no security specialisation. This makes it very likely that the code was written without security controls. For example, a poorly written login check could look like this:

```
SELECT * FROM users WHERE username = '[input]' AND password = '[input]';
```

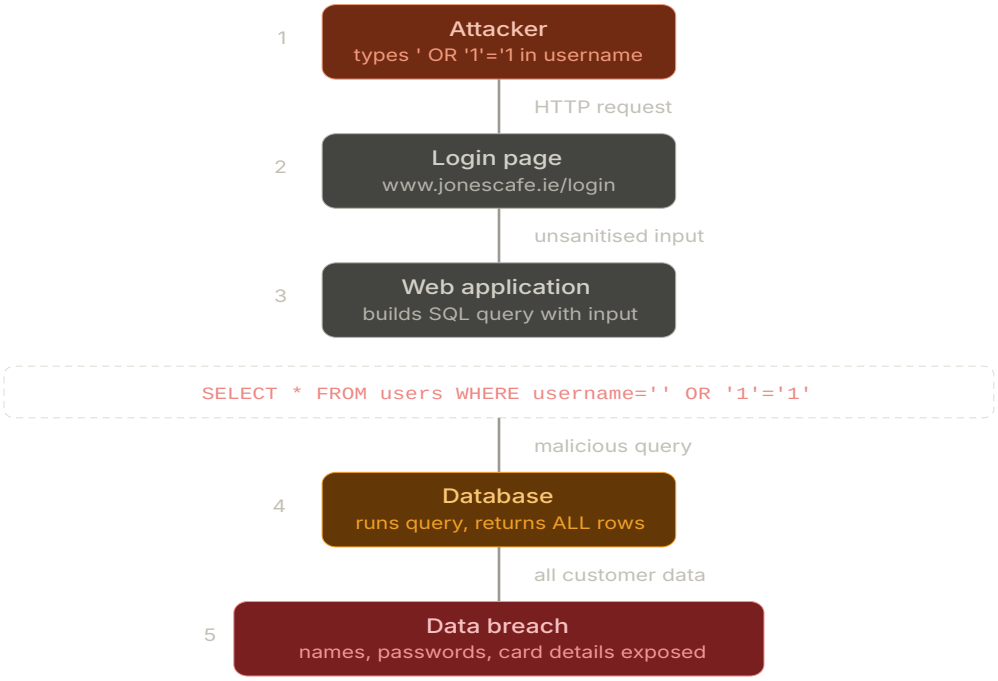
An attacker could type the following into the username field:

```
' OR '1'='1
```

This changes the query so it always returns true — giving the attacker access without a valid password. From there, they could read, modify, or delete all data in the database.

2.3 Example Attack Scenario

The diagram below shows how this attack works step by step against the Jones Café login page.



Step 1: Attacker finds the login page at www.jonescafe.ie/login

- **Step 2:** Types a single quote (') if a database error appears, the site is vulnerable
- **Step 3:** Injects ' OR '1'='1 into the username field
- **Step 4:** The database executes the malicious query and returns all user records
- **Step 5:** Attacker gains access to all customer data names, passwords, and payment details

A real example is the 2008 Heartland Payment Systems breach, where SQL Injection was used to steal 130 million credit card numbers (Schwartz, 2009). Jones Café faces exactly this risk if the vulnerability is not addressed before the website goes live.

2.4 Hardening Steps Before Going Live

The following steps should be completed before the web server is exposed to internet traffic:

- **Use parameterised queries:** This is the most important fix. Parameterised queries separate the SQL command from user input, so the database never runs injected code. Without this, an attacker can read or delete the entire database.
- **Validate all user input:** Each field should only accept the type of data it expects for example; a name field should reject quotes and semicolons. This adds a second layer of protection even if parameterised queries are already in place.

- **Apply least privilege to the database account:** The database user used by the web application should only be able to read and write not drop tables or access other databases. If an attack succeeds, the damage is limited.
- **Never show database errors to users:** Error messages often reveal table names and query structure. Always show a generic message. Attackers use error messages to refine their attacks.
- **Enable AWS WAF:** As recommended in Phase 1, AWS WAF can automatically block SQL Injection patterns before they reach the application adding a network-level layer of defence.

2.5 Conclusion

SQL Injection is one of the most serious risks for Jones Café because the website will process customer payment data. A successful attack could lead to a major data breach, financial loss, and GDPR penalties. The most important step is using parameterised queries, supported by input validation, restricted database permissions, and AWS WAF.

Phase 3: Incident Response Plan

3.1 Introduction

An Incident Response Plan (IRP) is a document that tells an organisation what to do when a cyberattack happens. Without a plan, staff will not know who to contact, what to do first, or how to limit the damage. For Jones Café, having a clear plan is especially important because most employees have little IT knowledge and the organisation handles customer payment data (NIST, 2018).

3.2 Preparation — Before an Attack Happens

The NIST SP 800-61 framework states that preparation is the most important phase organisations should do most of the work before any attack occurs (NIST, 2018). For Jones Café, preparation includes:

- **Assign an incident response contact:** Designate one person (for example, the IT manager) as the first point of contact when an incident is suspected. All staff must know who this person is.
- **Create a contact list:** Keep an up-to-date list of contacts including the IT manager, internet service provider, AWS support, and local Gardaí cybercrime unit. This list should be printed and stored offline in case systems are unavailable.
- **Back up all data regularly:** Backups should be made daily and stored in a separate location ideally on AWS S3 with versioning enabled. Without backups, a ransomware attack could permanently destroy all customer and business data.
- **Train staff:** All employees should know how to recognise a potential incident such as a computer behaving strangely, an unusual login alert, or a suspicious email and who to report it to immediately.

- **Document the normal network state:** Keep a record of what normal traffic and system behaviour looks like. This makes it much easier to spot something unusual during an attack.

3.3 Detection and Reporting

Detection means identifying that something has gone wrong. For Jones Café, an incident could be detected in several ways:

- A staff member notices the website is down or behaving strangely
- An alert from AWS GuardDuty or CloudTrail (recommended in Phase 1)
- A customer reports that their card was used fraudulently after shopping on the site
- Antivirus software detects malware on a staff computer

When an incident is suspected, the staff member must report it to the designated IT contact immediately — not try to fix it themselves. Acting without proper knowledge can make the situation worse. The date, time, and description of what was noticed should be written down straight away.

Severity	Description	Example	Response Time
Low	Minor issue, no data exposed, limited impact	Single staff PC with malware, no network spread	Within 24 hours
Medium	Some systems affected, possible data exposure	Brute force attack detected on SSH, suspicious login	Within 4 hours
High	Critical systems down or customer data exposed	Web server breached, database accessed, ransomware	Immediately

3.4 Containment

Containment means stopping the attack from spreading further. The steps depend on the type of incident, but in general Jones Café should:

- **Isolate affected systems:** Disconnect any compromised computer from the network immediately. For example, if the web server is attacked, it should be taken offline to prevent further data loss.
- **Change all passwords:** If credentials may have been stolen, change all passwords especially for Active Directory accounts, AWS IAM, and the website database.
- **Block suspicious IPs:** Use AWS Security Groups or the firewall to block any IP addresses identified as the source of the attack.
- **Preserve evidence:** Do not turn off affected systems or delete files before taking a copy of the logs. Evidence is needed for forensic investigation and may be required for GDPR reporting.

3.5 Forensic Analysis

After containment, the goal is to understand what happened and how. This includes:

- Reviewing AWS CloudTrail and server logs to identify when the attack started and what was accessed
- Checking which systems and data were affected
- Identifying how the attacker got in for example, through an unpatched vulnerability or a stolen password

If the breach involved customer payment data, Jones Café must report it to the Data Protection Commission (DPC) within 72 hours under GDPR. Failure to do so can result in significant fines (Data Protection Commission, 2021).

3.6 Recovery

Recovery means getting systems back to normal as safely and quickly as possible:

- **Restore from clean backups:** Only restore data from backups that were made before the attack occurred.
- **Patch the vulnerability:** Fix the security weakness that allowed the attack before bringing systems back online. Bringing a vulnerable system back online is the same as leaving the door open.
- **Test before going live:** Run a vulnerability scan with Nessus (Phase 7) before restoring public access to the website.
- **Notify affected customers:** If customer data was exposed, affected individuals must be informed as required by GDPR.

3.7 Lessons Learned

After every incident even a minor one the team should meet and ask: what happened, how did we respond, and what can we do better next time? The answers should be used to update this plan, improve staff training, and fix any gaps in the security setup. NIST SP 800-61 highlights this phase as essential for improving future response (NIST, 2018).

3.8 Conclusion

Jones Café does not currently have an incident response plan. Given the launch of an e-commerce website that stores customer payment data, this is a serious gap. Following the NIST SP 800-61 framework prepare, detect, contain, analyse, recover, and learn gives the organisation a clear and practical structure to follow in the event of a cyberattack.

Phase 4: Exploring Security Frameworks

4.1 Introduction

There are many frameworks and standards that help organisations build and maintain good security. Below is a brief overview of ten important ones, with examples of how each applies to Jones Café or the wider security industry.

1. GDPR – General Data Protection Regulation

GDPR is a European law that controls how organisations collect, store, and use personal data. For Jones Café, this means customer names, email addresses, and payment details must be stored securely and only used for the purpose they were collected. Strong GDPR compliance encourages better security practices — for example, encrypting databases and limiting who can access customer data. When companies are too relaxed about compliance, the consequences can be serious. In 2021, Amazon was fined €746 million for GDPR violations — the largest fine ever issued under the regulation (CNIL, 2021).

2. MITRE ATT&CK Framework

MITRE ATT&CK is a publicly available database of real attack techniques used by cybercriminals. Security teams use it to understand how attackers operate and to test their own defences. For example, it documents techniques like phishing, credential dumping, and lateral movement — all relevant to Jones Café. In April 2025, there was concern that US government funding for the MITRE CVE programme would be cut, which worried the security community because CVE is essential for tracking known vulnerabilities. Funding was ultimately continued, highlighting how critical this programme is to global cybersecurity (MITRE, 2025).

3. PCI-DSS – Payment Card Industry Data Security Standard

PCI-DSS is a set of security standards that any organisation handling credit or debit card payments must follow. Since Jones Café will accept online payments, PCI-DSS compliance is essential. Key requirements include encrypting card data in transit and at rest, using firewalls, and limiting access to payment systems. The easiest way for Jones Café to comply is to use a third-party payment provider like Stripe or PayPal, which handles card data on their own PCI-DSS certified infrastructure — meaning Jones Café never stores card numbers directly (PCI Security Standards Council, 2022).

4. NIST Cybersecurity Framework

The NIST Cybersecurity Framework gives organisations a structured way to manage cybersecurity risk. It is built around five core functions: Identify, Protect, Detect, Respond, and Recover. For Jones Café, this means identifying what assets need protecting (customer data, web server), putting protections in place (firewall, MFA), detecting threats (GuardDuty, IDS), responding to incidents (Phase 3 of this report), and recovering from attacks (backups, patch management). The framework is voluntary but widely used as a best practice guide (NIST, 2018).

5. SIEM – Security Information and Event Management

SIEM is a system that collects and analyses security logs from across the entire network in one place. Instead of checking logs on each individual server, a SIEM brings everything together and alerts the security team when something suspicious is detected. For example, if a SIEM sees five failed login attempts followed by a successful login from an unusual location, it will raise an alert. Common SIEM tools include Splunk and IBM QRadar. For Jones Café, AWS CloudTrail combined with Amazon GuardDuty provides a basic version of this functionality in the cloud (Splunk, 2023).

6. SOAR – Security Orchestration, Automation and Response

SOAR takes SIEM a step further by not just detecting threats but automatically responding to them. For example, if a SOAR system detects a brute force attack on the web server, it can automatically block the attacker's IP address without waiting for a human to act. This reduces response time significantly. While SOAR is more relevant for larger organisations with dedicated security teams, Jones Café could benefit from basic automation through AWS Security Hub, which can trigger automatic responses to certain types of alerts (Palo Alto Networks, 2023).

7. CVSS – Common Vulnerability Scoring System

CVSS is a scoring system that rates the severity of security vulnerabilities on a scale from 0 to 10. A score of 0 means no risk, while 10 is the most critical. For example, CVE-2017-0144 — the EternalBlue vulnerability used in WannaCry — received a CVSS score of 9.8, meaning it was extremely dangerous. Security teams use CVSS scores to prioritise which vulnerabilities to fix first. For Jones Café, when Nessus (Phase 7) finds vulnerabilities, it uses CVSS scores to help decide which ones need to be patched immediately (NIST, 2019).

8. ISO 27001 – Information Security Management Systems

ISO 27001 is an international standard for managing information security. It provides a framework for identifying risks, implementing controls, and continuously improving security. Organisations can become certified, which shows customers and partners that they take security seriously. For Jones Café, full ISO 27001 certification may not be realistic with a limited budget, but following its principles — such as regular risk assessments, access control policies, and documented procedures — would significantly improve their security posture (ISO, 2022).

9. Lockheed Martin Cyber Kill Chain

The Cyber Kill Chain is a model developed by Lockheed Martin that describes the seven stages of a cyberattack: Reconnaissance, Weaponisation, Delivery, Exploitation, Installation, Command and Control, and Actions on Objectives. Understanding these stages helps defenders stop an attack early. For example, if Jones Café blocks phishing emails (Delivery stage), the attacker never gets to install malware. The Kill Chain is useful for understanding how attacks like the WannaCry ransomware (discussed in Phase 1) progressed and where defences could have stopped them (Lockheed Martin, 2022).

10. Benefits of Implementing ISO/IEC 27001

Implementing ISO/IEC 27001 brings several practical benefits beyond just security. It demonstrates to customers that their data is being handled responsibly, which builds trust — especially important for an e-commerce business like Jones Café. It helps the organisation meet legal obligations such as GDPR. It also reduces the risk of costly incidents: the IBM Cost of a Data Breach Report 2023 found that organisations with strong security frameworks paid on average $1.76 million less per breach than those without (IBM, 2023). For a small business, even a small breach could be financially devastating.

Phase 5: Demonstrate an Attack Against a Vulnerable Machine 1

5.1 Lab Setup

For this phase, Kali Linux is used as the attacker and Metasploitable2 as the victim. Both virtual machines are configured with Host-Only network adapters so they can communicate with each other on the same virtual network without internet access. The IP addresses are:

Kali Linux (Attacker): 192.168.56.14

Metasploitable2 (Victim): 192.168.56.200

The screenshot below confirms the sandbox setup and that both machines can communicate via PING.

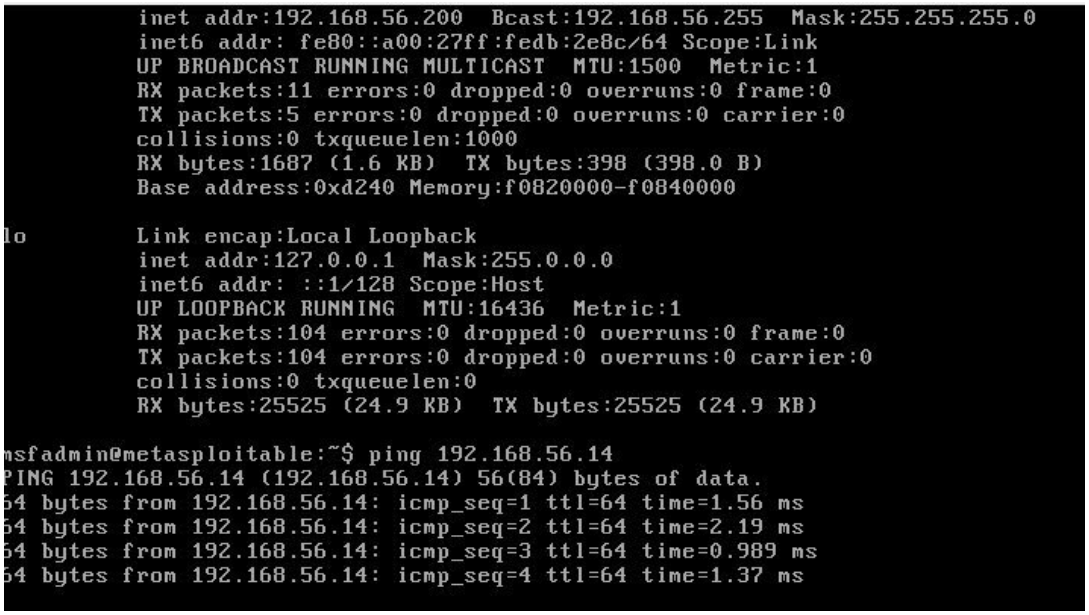


Figure 10: PING confirmation between Kali Linux and Metasploitable2

5.2 NMAP Scans

NMAP (Network Mapper) is a free and open-source tool used to discover hosts and services on a network. The following five scans were performed against the Metasploitable2 target (192.168.56.200).

Scan 1 – Basic Scan: nmap 192.168.56.200

A basic NMAP scan with no extra options lists all open TCP ports on the target. It shows the port number, state (open/closed), and the service name. This gives a quick overview of what is running on the machine — in this case, over 20 open ports including FTP, SSH, Telnet, HTTP, and MySQL. The number of open ports on Metasploitable2 is intentionally high as it is a vulnerable machine designed for practice.

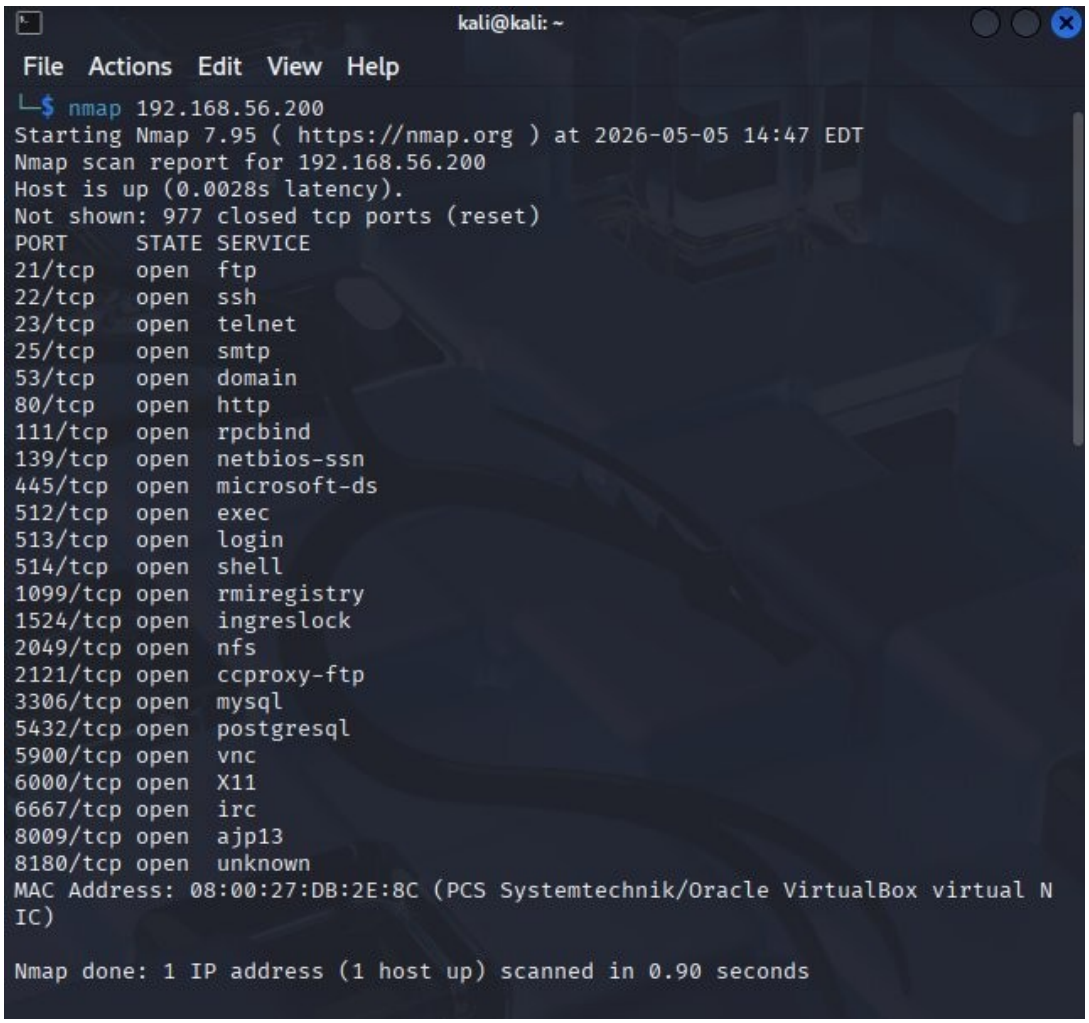


Figure 11: nmap 192.168.56.200 – basic scan showing open ports

Scan 2 – Version Detection: nmap -sV 192.168.56.200

The -sV flag tells NMAP to detect the version of each service running on the open ports. This is very useful for an attacker because knowing the exact version of a service allows them to search for known vulnerabilities. For example, the scan reveals vsftpd 2.3.4 on port 21 — a version known to contain a backdoor vulnerability (CVE-2011-2523). It also shows MySQL 5.0.51a and Apache 2.2.8, both outdated and vulnerable.

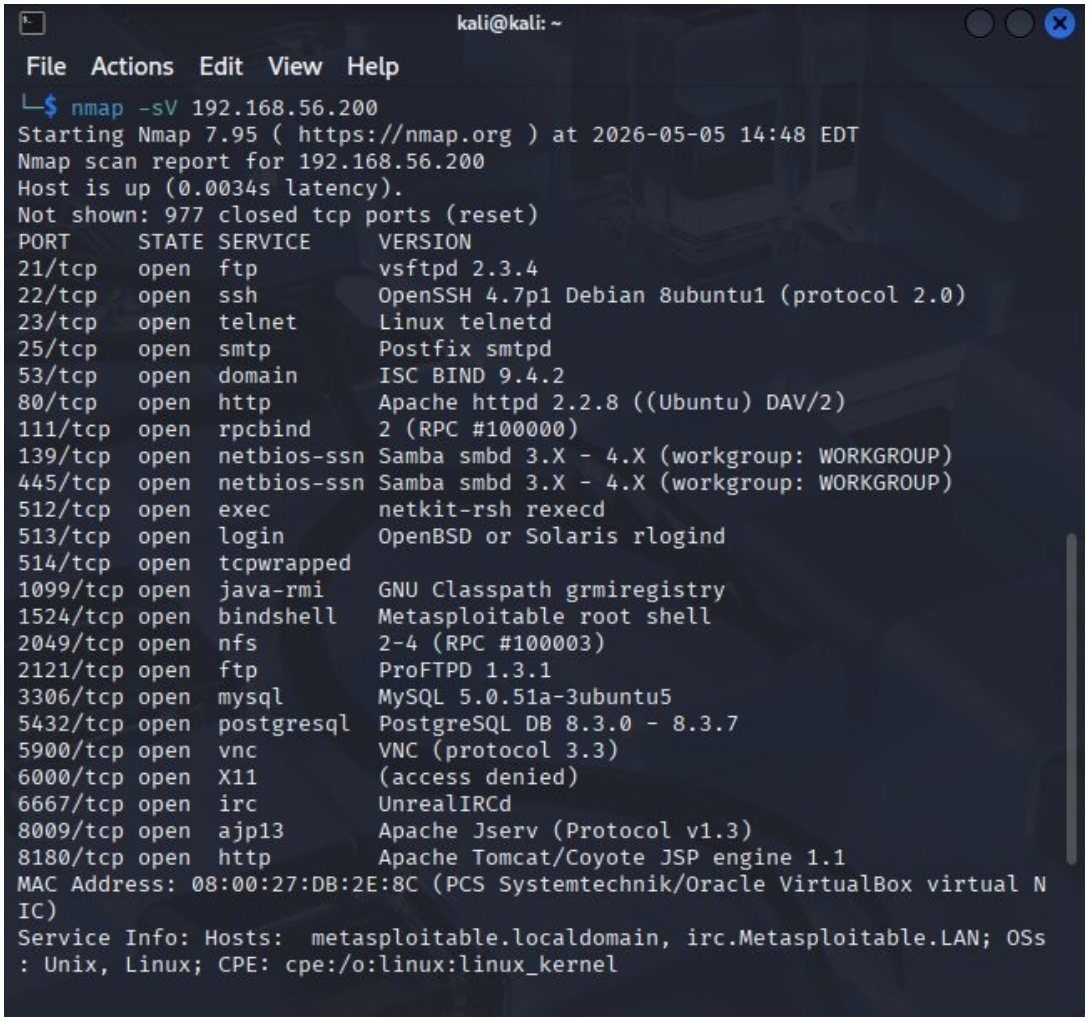


Figure 12: nmap -sV – version detection scan

Scan 3 – OS Detection: nmap -O 192.168.56.200

The -O flag attempts to identify the operating system of the target machine. NMAP analyses the responses from the target and compares them against a database of known OS fingerprints. The scan correctly identifies the target as running Linux kernel version 2.6.9 to 2.6.33, which matches the Metasploitable2 system. Knowing the OS helps an attacker choose the right exploits.

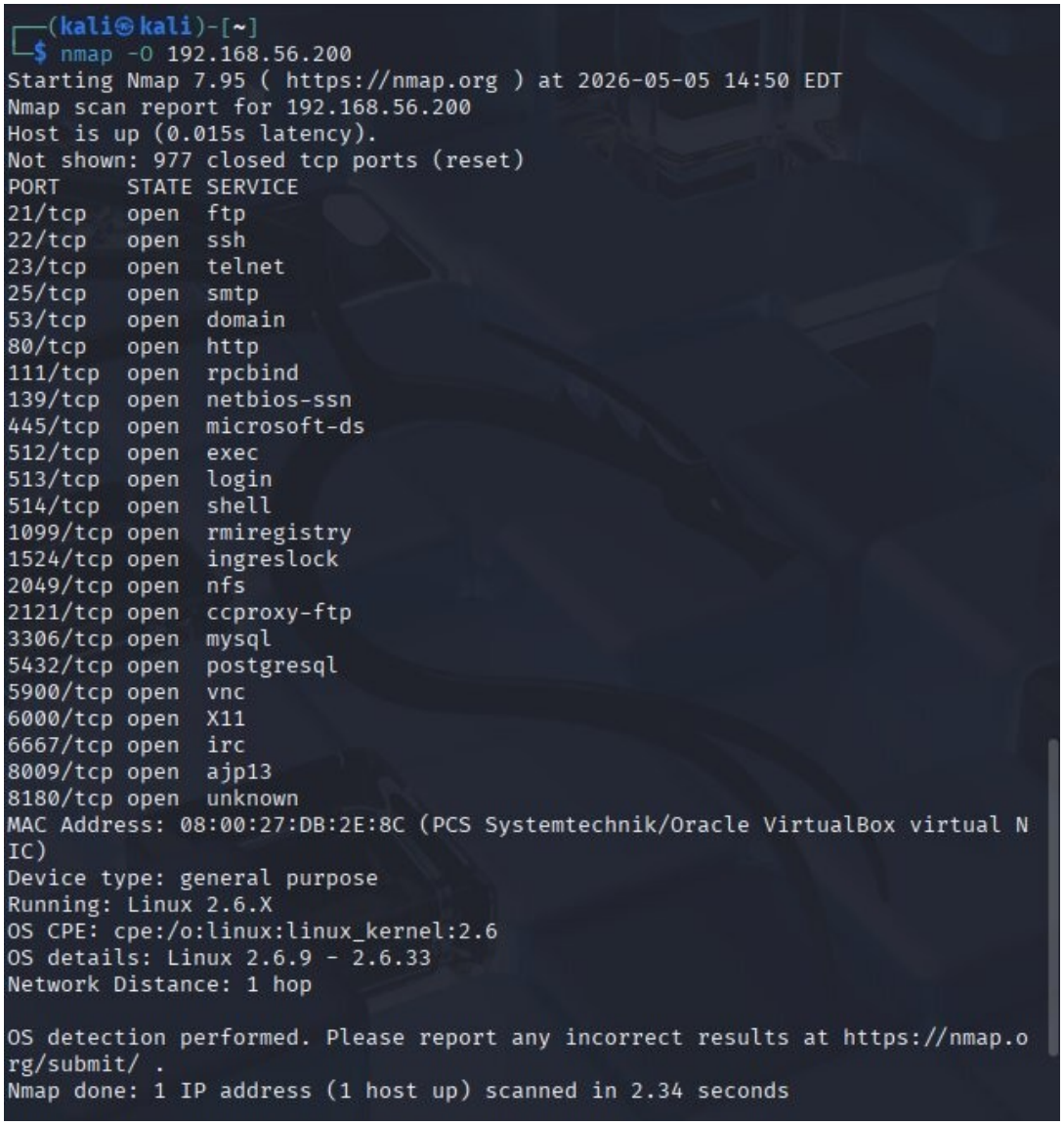


Figure 13: nmap -O – OS detection scan

Scan 4 – SYN Stealth Scan: nmap -sS 192.168.56.200

The -sS flag performs a SYN scan, also known as a stealth scan. Instead of completing the full TCP handshake, NMAP sends a SYN packet and waits for a response — if the port is open it receives a SYN-ACK, but never completes the connection. This makes the scan harder to detect in logs. The results show the same open ports but the scan completed in under 1 second, much faster than a full connect scan.

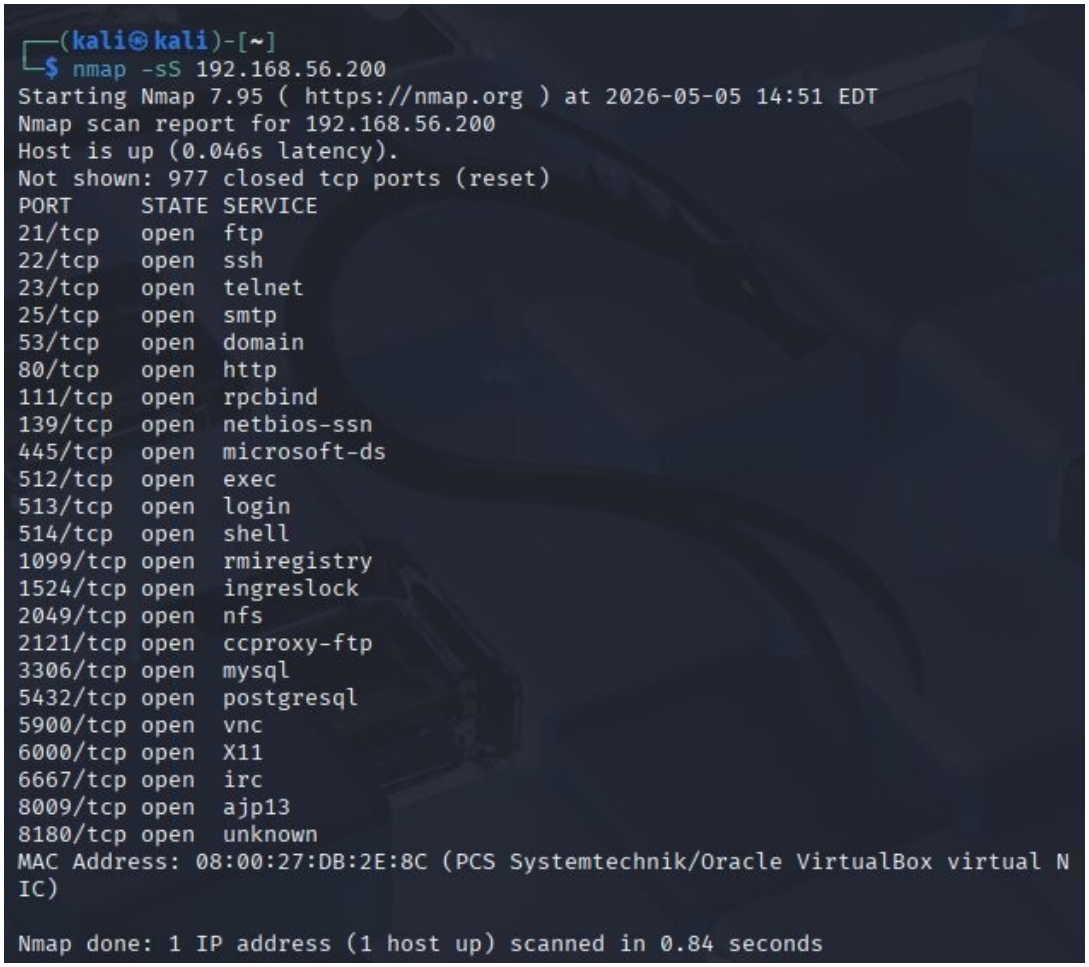


Figure 14: nmap -sS – SYN stealth scan

Scan 5 – Aggressive Scan: nmap -A 192.168.56.200

The -A flag enables an aggressive scan that combines OS detection, version detection, script scanning, and traceroute in one command. This gives the most detailed picture of the target. The results include SSH host keys, FTP status (anonymous login allowed), SSL certificate details, Samba version, MySQL protocol information, and VNC authentication type. This level of detail would allow an attacker to plan a very targeted attack. The scan took 28.97 seconds to complete.

```
┌──(kali㉿kali)-[~]
└─$ nmap -A 192.168.56.200
Starting Nmap 7.95 ( https://nmap.org ) at 2026-05-05 14:52 EDT
Nmap scan report for 192.168.56.200
Host is up (0.019s latency).
Not shown: 977 closed tcp ports (reset)
PORT     STATE SERVICE     VERSION
21/tcp   open  ftp         vsftpd 2.3.4
| ftp-syst:
|   STAT:
| FTP server status:
|      Connected to 192.168.56.14
|      Logged in as ftp
|      TYPE: ASCII
|      No session bandwidth limit
|      Session timeout in seconds is 300
|      Control connection is plain text
|      Data connections will be plain text
|      vsFTPd 2.3.4 - secure, fast, stable
|_End of status
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
22/tcp   open  ssh         OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
| ssh-hostkey:
|   1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
|_  2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
23/tcp   open  telnet      Linux telnetd
25/tcp   open  smtp        Postfix smtpd
| sslv2:
|   SSLv2 supported
|   ciphers:
|     SSL2_RC4_128_WITH_MD5
|     SSL2_RC2_128_CBC_EXPORT40_WITH_MD5
|     SSL2_RC2_128_CBC_WITH_MD5
|     SSL2_DES_64_CBC_WITH_MD5
|     SSL2_DES_192_EDE3_CBC_WITH_MD5
|_    SSL2_RC4_128_EXPORT40_WITH_MD5
|_ssl-date: 2026-05-05T18:39:54+00:00; -12m46s from scanner time.
| ssl-cert: Subject: commonName=ubuntu804-base.localdomain/organizationName=O
COSA/stateOrProvinceName=There is no such thing outside US/countryName=XX
| Not valid before: 2010-03-17T14:07:45
|_Not valid after:  2010-04-16T14:07:45
|_smtp-commands: metasploitable.localdomain, PIPELINING, SIZE 10240000, VRFY,
```

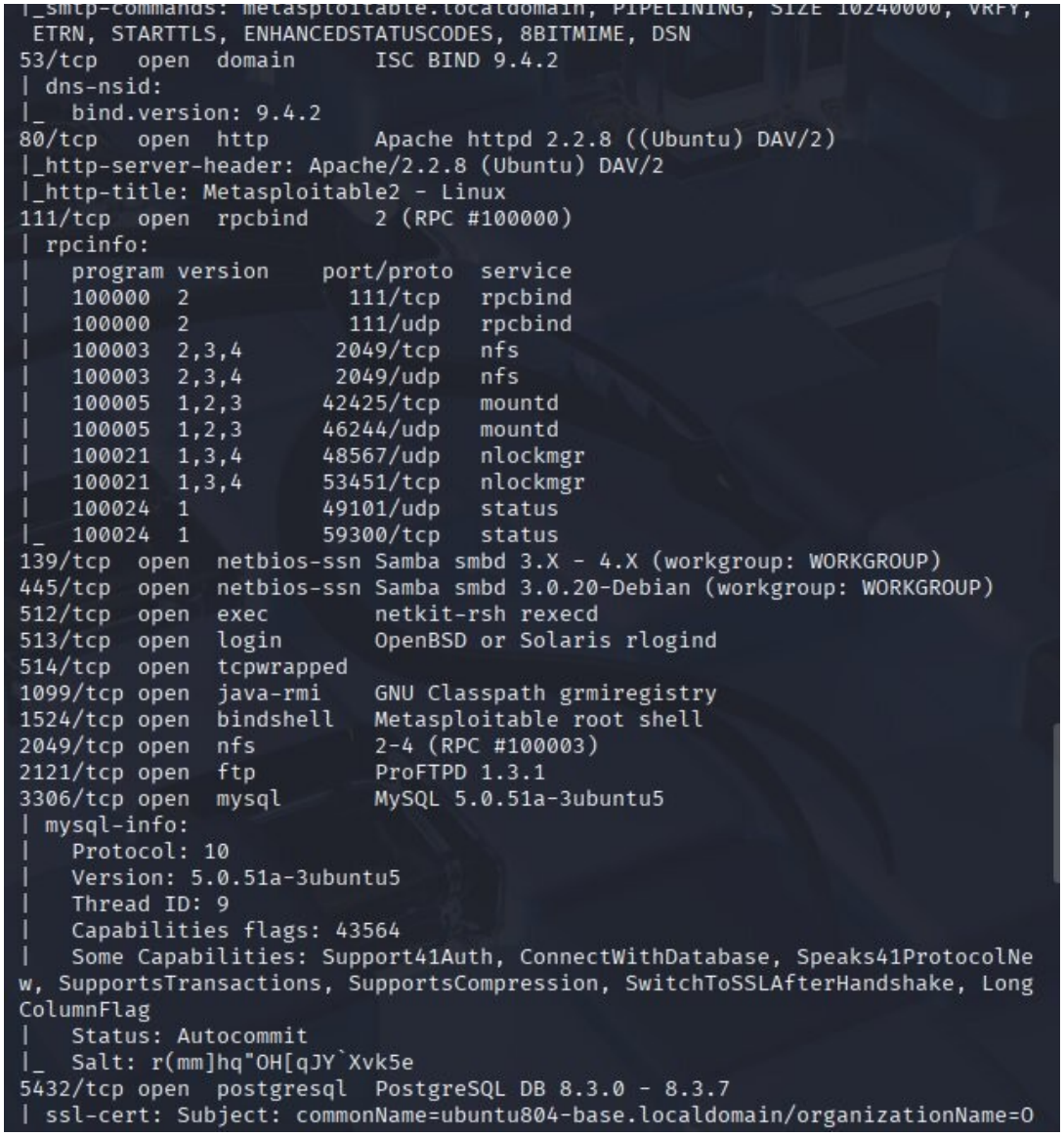


Figure 15: nmap -A – aggressive scan (continued)

5.3 Key Findings

The scans revealed that Metasploitable2 has a very large attack surface with many dangerous services running. The most critical findings are:

- **vsftpd 2.3.4 (port 21):** contains a known backdoor — CVE-2011-2523
- **Telnet (port 23):** transmits all data in plain text including passwords
- **Anonymous FTP login allowed:** anyone can access the FTP server without a password
- **MySQL (port 3306):** exposed to the network — database should never be publicly accessible
- **SMB message signing disabled:** makes the machine vulnerable to man-in-the-middle attacks

References

Amazon Web Services (2024) AWS Security Services Overview. Available at: https://aws.amazon.com/security/ (Accessed: 2 May 2026).

Cisco (2021) Securing the Local Area Network. Available at: https://www.cisco.com/c/en/us/td/docs/solutions/Enterprise/Security/SBA_Security_Guide.html (Accessed: 30 April 2026).

Cisco (2021) VLAN Best Practices and Security Tips for Cisco Business Routers. Available at: https://www.cisco.com/c/en/us/support/docs/smb/routers/cisco-rv-series-small-business-routers/1778-tz-VLAN-Best-Practices-and-Security-Tips-for-Cisco-Business-Routers.html (Accessed: 30 April 2026).

MITRE (2024) CVE-2017-0144 – EternalBlue SMB Remote Code Execution. Available at: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2017-0144 (Accessed: 1 May 2026).

National Cyber Security Centre (NCSC) (2018) WannaCry ransomware attack: technical analysis. Available at: https://www.ncsc.gov.uk/information/wannacry-ransomware-attack-technical-analysis (Accessed: 1 May 2026).

National Cyber Security Centre Ireland (NCSC Ireland) (2023) Annual Report 2023. Available at: https://www.ncsc.gov.ie/annual-reports/ (Accessed: 1 May 2026).

NIST (2020) SP 800-53 Rev. 5: Security and Privacy Controls for Information Systems and Organizations. Available at: https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-53r5.pdf (Accessed: 30 April 2026).

NIST (2022) SP 800-40 Rev. 4: Guide to Enterprise Patch Management Planning. Available at: https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-40r4.pdf (Accessed: 1 May 2026).

Verizon (2024) 2024 Data Breach Investigations Report. Available at: https://www.verizon.com/business/resources/reports/dbir/ (Accessed: 2 May 2026).

Weiss, M. (2026) Network and System Security – Lecture Slides: Mitigating Threats Part I, Security Fundamentals, Securing the LAN. CCT College Dublin [Unpublished lecture material].

OWASP (2021) OWASP Top 10:2021 – A03 Injection. Available at:

https://owasp.org/Top10/A03_2021-Injection/ (Accessed: 2 May 2026).

OWASP (2017) OWASP Top 10 – 2017: The Ten Most Critical Web Application Security Risks. Available at: https://owasp.org/www-project-top-ten/2017/Top_10 (Accessed: 2 May 2026).

OWASP (2023) SQL Injection Prevention Cheat Sheet. Available at: https://cheatsheetseries.owasp.org/cheatsheets/SQL_Injection_Prevention_Cheat_Sheet.html (Accessed: 3 May 2026).

Schwartz, M. J. (2009) Heartland Data Breach: 130 Million Cards Compromised. Available at: https://www.informationweek.com/it-life/heartland-data-breach-130-million-cards-compromised (Accessed: 3 May 2026).

Weiss, M. (2026) Network and System Security – OWASP Top 10 Document. CCT College Dublin [Unpublished lecture material].

Data Protection Commission (2021) Guidance on Personal Data Breaches. Available at: https://www.dataprotection.ie/en/individuals/personal-data-breaches (Accessed: 3 May 2026).

NIST (2018) SP 800-61 Rev. 2: Computer Security Incident Handling Guide. Available at: https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-61r2.pdf (Accessed: 3 May 2026).

Weiss, M. (2026) Network and System Security – Lecture Slides. CCT College Dublin [Unpublished lecture material].

CNIL (2021) The CNIL's Restricted Committee Imposes a Financial Penalty of 746 Million Euros Against Amazon Europe Core. Available at: https://www.cnil.fr/en/cnils-restricted-committee-imposes-financial-penalty-746-million-euros-against-amazon-europe-core (Accessed: 3 May 2026).

IBM (2023) Cost of a Data Breach Report 2023. Available at: https://www.ibm.com/reports/data-breach (Accessed: 4 May 2026).

ISO (2022) ISO/IEC 27001:2022 Information Security Management Systems. Available at: https://www.iso.org/standard/82875.html (Accessed: 3 May 2026).

Lockheed Martin (2022) The Cyber Kill Chain. Available at: https://www.lockheedmartin.com/en-us/capabilities/cyber/cyber-kill-chain.html (Accessed: 4 May 2026).

MITRE (2025) CVE Programme. Available at: https://www.cve.org (Accessed: 4 May 2026).

NIST (2018) Framework for Improving Critical Infrastructure Cybersecurity. Available at: https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.04162018.pdf (Accessed: 3 May 2026).

NIST (2019) Common Vulnerability Scoring System (CVSS). Available at: https://www.nist.gov/publications/common-vulnerability-scoring-system (Accessed: 4 May 2026).

Palo Alto Networks (2023) What is SOAR? Available at: https://www.paloaltonetworks.com/cyberpedia/what-is-soar (Accessed: 4 May 2026).

PCI Security Standards Council (2022) PCI DSS Quick Reference Guide. Available at: https://www.pcisecuritystandards.org/documents/PCI_DSS-QRG-v3_2_1.pdf (Accessed: 3 May 2026).

Splunk (2023) What is SIEM? Available at: https://www.splunk.com/en_us/data-insider/what-is-siem.html (Accessed: 4 May 2026).

Weiss, M. (2026) Network and System Security – Lecture Slides. CCT College Dublin [Unpublished lecture material].

Gordon, L. (2023) NMAP Network Scanning: The Official NMAP Project Guide. Available at: https://nmap.org/book/ (Accessed: 5 May 2026).

MITRE (2011) CVE-2011-2523: vsftpd 2.3.4 Backdoor. Available at: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2011-2523 (Accessed: 5 May 2026).

Weiss, M. (2026) Network and System Security – Lecture Slides. CCT College Dublin [Unpublished lecture material].